



SOUFER Tools

Relatório 2 — correções e revalidação

Tudo o que a primeira auditoria encontrou, corrigido e testado de novo — mais ensaio da implantação, resiliência, servidor pequeno, acessibilidade e fluxos pela tela.

Data: 09/10/2026 · Implantação prevista: terça-feira, 13/10/2026

Branch: fix/auditoria-prontidao-implantacao (12 commits sobre development @ e5f4a60) · local, sem push

Ambiente: build de produção (NODE_ENV=production), PostgreSQL 14, banco recriado do zero (soufer_v2)

PI 2026.2 · Desenvolvimento de Soluções Web Inteligentes e Integradas

1. Sumário executivo

Veredito: pronto para implantar na terça. Os três bloqueantes do relatório 1 foram corrigidos, assim como todos os itens de atenção que eram do código. A segunda rodada de testes encontrou **dois problemas novos e sérios** que a primeira não pegava — a API caía se o banco derrubasse as conexões no meio de uma transação, e a exportação de CSV congelava a API inteira — e os dois também foram corrigidos. Ao todo foram 12 commits numa branch própria (sem push), 352/352 testes na API e 48/48 no front, 468.809 requisições de carga sem nenhum erro de servidor, 59/60 casos de segurança e o **ensaio completo da terça** (banco zerado até a primeira retirada) passando em ~2 s.

Antes × depois, por achado

Achado (relatório 1)	Antes	Depois	
Carga inicial de ferramentas (CSV, banco vazio)	800 linhas: 60,3 s (no limite do proxy)	1.000 linhas: 1,5 s no ensaio	RESOLVIDO
Cadastro de 500 ferramentas pela tela	43,3 s, cada um mais lento	3,5 s, constante	RESOLVIDO
Seed com senha 123456 em produção	guia mandava rodar	seed recusa produção; db:admin cria o admin por link	RESOLVIDO
Variáveis/guia de deploy	faltava TRUST_PROXY_HOPS, volume, backup	guia atualizado e testado	RESOLVIDO
Rolagem horizontal em 768 px	9 aberturas de tela com estouro	0 em 51 aberturas	RESOLVIDO
JSON malformatado	500 + log de erro	400 INVALID_JSON	RESOLVIDO
Enumeração de matrícula pelo tempo do login	3 ms × 62 ms	57 ms × 57 ms	RESOLVIDO
/v1/health expõe nome do banco	soufer_audit	null em produção	RESOLVIDO
npm audit (produção)	API 1 crítica · front 15	API 0 · front 0	RESOLVIDO
Bundle inicial do front	969 KB (1 arquivo)	494 KB + telas sob demanda	RESOLVIDO
Histórico de empréstimos (lista)	p50 40 ms	p50 16 ms (índice)	RESOLVIDO
Botão de imprimir pendências (visita técnica)	não existia	lista A4 no dashboard	RESOLVIDO
Título revela rota de admin / 404 dizia "Dashboard"	sim	"Página não encontrada"	RESOLVIDO
Cabeçalhos de segurança no front	ausentes	CSP, X-Frame-Options, nosniff...	RESOLVIDO
Novo: queda de conexão do banco derrubava a API	—	API segue; 0,05% de falhas no instante	NOVO — RESOLVIDO
Novo: exportação CSV congelava a API	sonda esperando 7,3 s	1,3 s com 10 simultâneas	NOVO — RESOLVIDO
Novo: acessibilidade (axe-core)	1 crítico em 15 telas	0 críticos	NOVO — RESOLVIDO
Contraste das cores de status (verde/âmbar)	—	decisão de design do time	PENDENTE
Swagger público em produção	—	mantido (entregável do PI)	PENDENTE

2. O que foi alterado no código

Todas as mudanças estão na branch `fix/auditoria-prontidao-implantacao`, criada a partir da `development` atualizada (git pull feito: o último commit do remoto é o merge do PR #189). Nada foi enviado ao GitHub. O PR #190 (notificações) não foi tocado e não conflita: os arquivos dele (`server.ts`, `SinoNotificacoes.tsx`) ficaram de fora.

Commit	Mudança
a8417df	fix(web): ficha da ferramenta com lista de definição válida (dt/dd direto na dl)
4dae634	fix(web): acessibilidade apontada pelo axe-core nas telas principais
93c1d69	perf(api): exportação de empréstimos formata datas no Postgres e não congela a API
7122416	fix(api): queda da conexão do banco durante uma transação não derruba mais a API
36b2b75	feat(web): imprimir a lista de cobrança (atrasados e devoluções de hoje) em A4
57e4dcf	perf(web): carrega cada tela sob demanda e cabeçalhos de segurança no serve
8ac4e87	fix(web): sem rolagem horizontal em 768 px e título que não revela rota de admin
212f6ec	feat(api): db:admin cria o primeiro admin por link de convite e seed recusa produção
486c8e8	fix(api): /v1/health em produção não expõe nome do banco nem erro cru do driver
d0818b3	fix(api): login de matrícula sem conta também roda o bcrypt
112b34e	fix(api): JSON malformatado no corpo responde 400 INVALID_JSON em vez de 500
0904a0d	fix(db): geração do código da ferramenta independente do plano e índice do histórico

Arquivos principais

- **API:** migration `0011_desempenho_codigo_e_historico.sql` (gatilho do código + índice do histórico), `errorHandler` (JSON malformatado), `authService` (bcrypt para matrícula sem conta), `healthController`, `config/database.ts` (ouvinte de erro em todo cliente do pool), `exportacaoService` (datas no Postgres), `scripts/criar-admin.ts` (novo `npm run db:admin`), `scripts/seed.ts` (recusa produção), `npm audit fix`.
- **Testes novos (API):** JSON malformatado → 400; bcrypt roda para matrícula sem conta; conexão emprestada que cai não derruba o processo (falha sem a correção, verificado); 300 ferramentas numa transação com códigos distintos.
- **Front:** `min-w-0` no conteúdo do layout (estouro em 768 px), título do cabeçalho, carregamento de telas sob demanda, `ImprimirPendencias` (lista A4), acessibilidade, rodapé do fluxo no celular, `serve` fixo + `public/serve.json` com cabeçalhos de segurança, `shadcn` em `devDependencies`, remoção do pacote `npm cn` usado por engano no Avatar.
- **Documentação:** `docs/nuvem/dokploy.md` (db:admin no lugar do seed, `TRUST_PROXY_HOPS`, `UPLOADS_DIR`, backup, porta da API não exposta, carga inicial) e `api/README.md`.

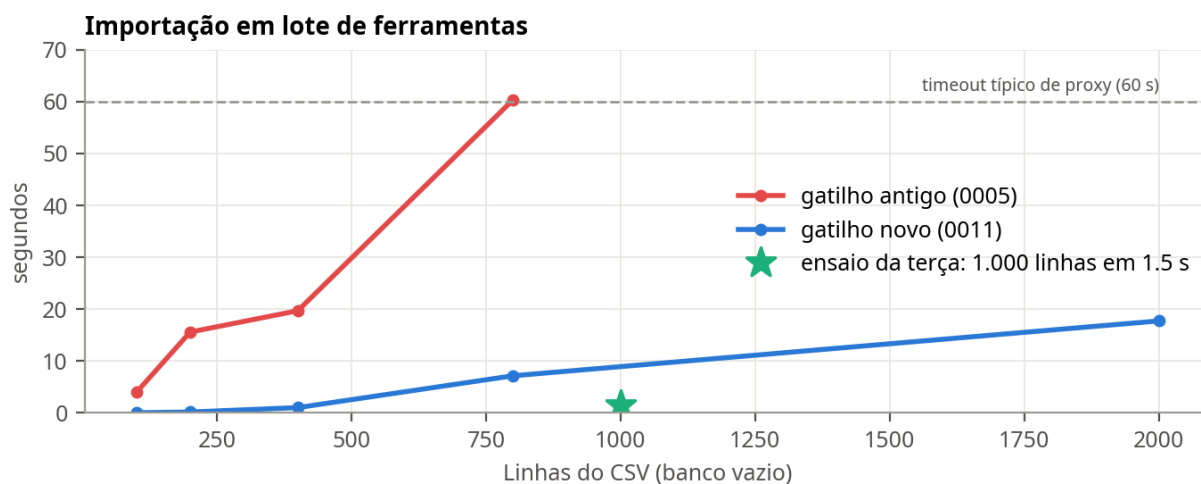
Tamanho da mudança: 34 arquivos, +1.858/−276 linhas (a maior parte é `package-lock.json`). Typecheck, build, checagem de animação e lint (15 avisos de estilo, 0 erros) passam.

3. Ensaio da implantação de terça

O cenário real foi reproduzido do zero: banco vazio, só `npm run db:migrate` e `npm run db:admin`, API em modo produção. Daí em diante tudo pela API, na ordem em que a equipe vai fazer na Soufer.

Passo	Tempo	Resultado
Responsável Manutenção	39 ms	status: 200
2. Admin define o PIN e entra	73 ms	status: 200, papel: admin
3. Link usado de novo é recusado	68 ms	status: 410, erro: CONVITE_JA_USADO
4. Importa setores (CSV)	15 ms	status: 200, total_linhas: 8, aceitas: 7, rejeitadas: 0, ignoradas: 1
5. Importa categorias (CSV)	10 ms	status: 200, total_linhas: 6, aceitas: 6, rejeitadas: 0, ignoradas: 0
6. Importa 400 colaboradores (CSV)	147 ms	status: 200, total_linhas: 400, aceitas: 400, rejeitadas: 0, ignoradas: 0
7. Importa 1.000 ferramentas (CSV, banco vazio)	1456 ms	status: 200, total_linhas: 1000, aceitas: 1000, rejeitadas: 0, ignoradas: 0
8. Admin gera link de acesso de um operador	15 ms	status: 201, colaborador: 0100
9. Operador define PIN e entra	61 ms	status: 200, papel: manutencao
10. Primeira retirada (código lido + matrícula)	164 ms	status: 201, ferramenta: LIXADEIRA 1, colaborador: Colaborador Ensaio 51, registradoPor: Colaborador Ensaio 1
11. Dashboard reflete a retirada	8 ms	status: 200, cadastradas: 1000, disponiveis: 999, em_uso: 1, indisponiveis: 0, atrasadas: 0, ocorrencias: 0
12. Devolução com avaria abre ocorrência	8 ms	status: 200, resumo: LIXADEIRA 1 foi para indisponível por avaria.
13. Quiosque consulta disponibilidade	8 ms	status: 200, total: 100, campos: id,nome,categoria,status,localizacao,codigo_identificacao

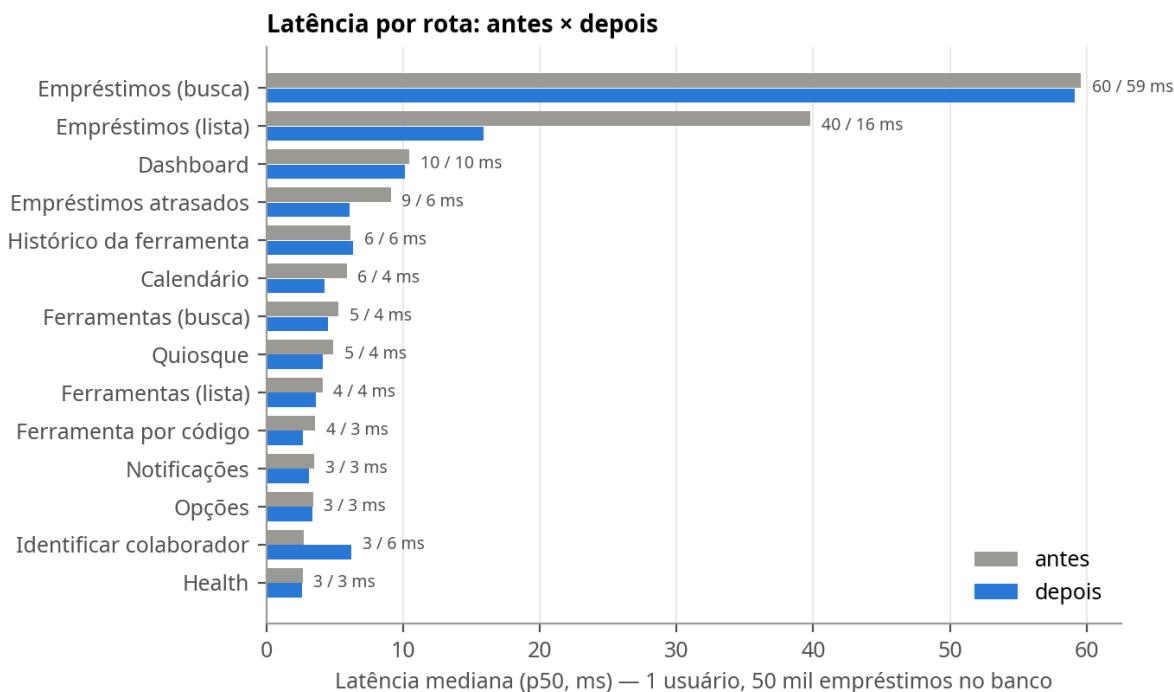
Total do ensaio: 2.1 s. Migrations do zero: 0,75 s. O link de convite usado de novo é recusado (410), o operador entra com o próprio PIN, a retirada grava o operador logado como responsável (regra 6), a devolução com avaria abre a ocorrência (regra 3) e o quiosque só vê nome, categoria, status e localização (regra 8).



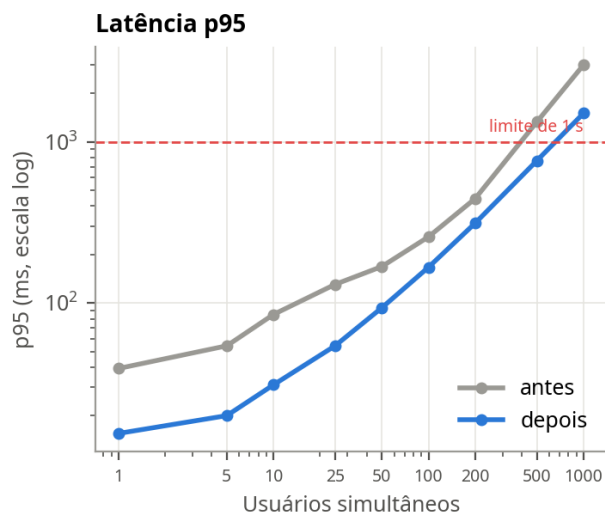
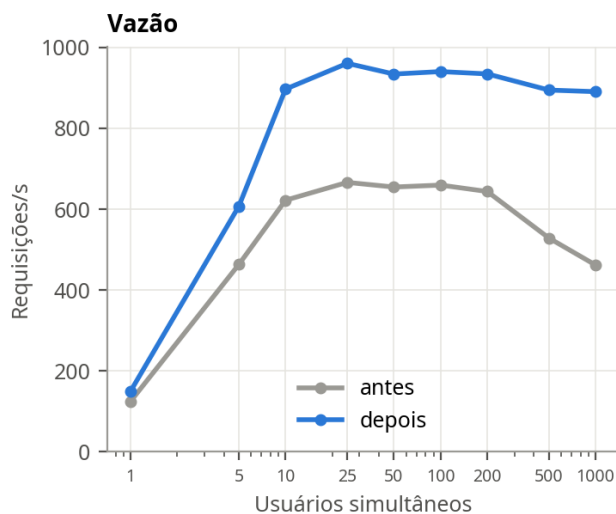
Importação em lote em banco vazio. A estrela é a importação real do ensaio (1.000 linhas, com categorias e setores resolvidos por nome).

Seed recusado em produção (testado): "db:seed recusado com NODE_ENV=production (cria contas com senha 123456). Use `npm run db:admin`."

4. Performance, carga e resistência — antes × depois



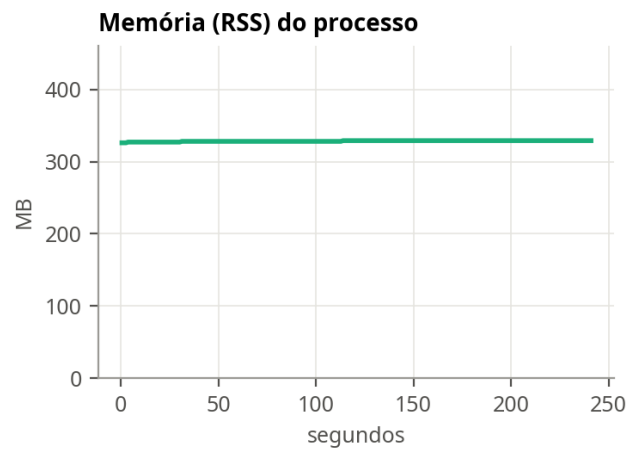
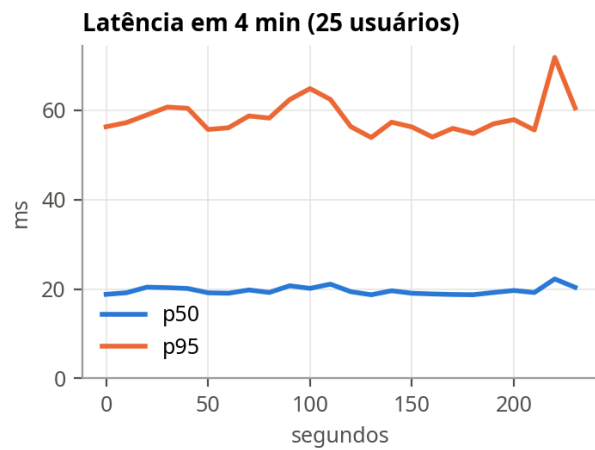
Mesma bateria da rodada 1. A busca de colaborador mudou de termo (nome em vez de matrícula) e não é comparável. A única rota que ainda passa de 20 ms é a **busca no histórico** (~60 ms): é ILIKE com curinga dos dois lados sobre a view de 50 mil linhas. Imperceptível hoje; vira candidata a índice trigram se o histórico passar de 5 anos.



Usuários	Req/s antes	Req/s depois	p95 antes	p95 depois	5xx antes	5xx depois
1	125	150	39 ms	16 ms	0	0
5	463	607	54 ms	20 ms	0	0
10	622	897	85 ms	31 ms	0	0
25	666	960	131 ms	54 ms	0	0
50	655	934	169 ms	94 ms	0	0
100	660	940	258 ms	167 ms	0	0
200	644	934	445 ms	313 ms	0	0
500	528	894	1330 ms	764 ms	0	0
1000	462	890	3003 ms	1505 ms	0	0

Vazão máxima de ~660 para ~960 req/s e p95 bem menor em todos os degraus; com 500 usuários o p95 agora fica abaixo de 1 s. **Ressalva honesta:** a base da rodada 2 tem 1.030 ferramentas (do ensaio) contra 1.530 na rodada 1, com os mesmos ~50 mil empréstimos — parte do ganho vem disso; o resto vem do índice do histórico, que era a rota mais pesada da mistura.

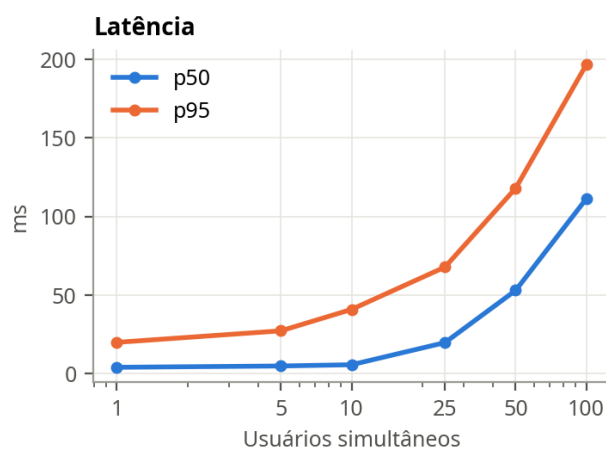
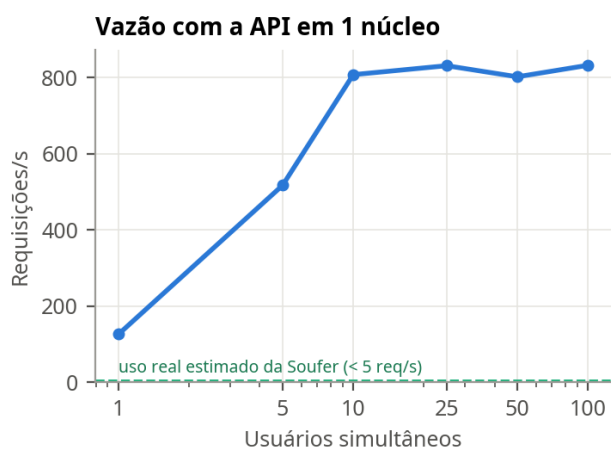
Resistência (4 min, 25 usuários)



Rodada 2: 219.106 requisições, 913 req/s, p95 58 ms, 0 erros 5xx (rodada 1: 517 req/s, p95 186 ms). Memória estável, sem vazamento.

5. Servidor pequeno: API presa a 1 núcleo e 256 MB

O servidor previsto (EC2 t3.micro: 2 vCPU com crédito, 1 GB) é bem mais modesto que a máquina de teste. Para simular, a API foi presa a um único núcleo (taskset -c 3) com heap limitado a 256 MB (-max-old-space-size=256) e recebeu a mesma mistura de carga.



Usuários	Req/s	p50	p95	p99	Erros
1	126	4 ms	20 ms	78 ms	0
5	517	5 ms	27 ms	112 ms	0
10	808	6 ms	41 ms	157 ms	0
25	831	20 ms	68 ms	219 ms	0
50	802	53 ms	118 ms	252 ms	0
100	832	111 ms	197 ms	291 ms	0

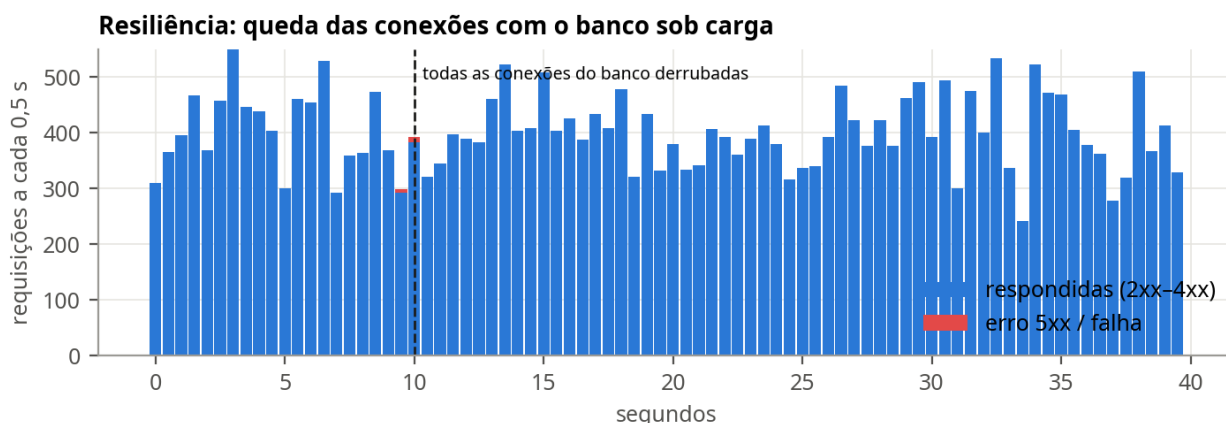
Mesmo em 1 núcleo a API sustenta ~830 req/s sem erros e a memória máxima do processo ficou em **231 MB** (pico medido em /proc). O uso real estimado da Soufer fica abaixo de 5 req/s: mais de 150× de folga. Nesse cenário o Postgres continuou com todos os núcleos; num servidor com banco e API juntos, a folga é menor mas continua grande.

6. Resiliência e operação

Achado novo: a API caía quando o banco derrubava as conexões

Teste: com 25 usuários em carga, todas as conexões da API no Postgres foram encerradas à força aos 10 s (`pg_terminate_backend`) — o que acontece num reinício do Postgres, failover do RDS ou rede piscando.

Na primeira execução o processo da API morreu ("Unhandled 'error' event"): o `pg-pool` tira o ouvinte de erro do cliente enquanto ele está emprestado para uma transação (dashboard, retirada, devolução). A correção registra um ouvinte em todo cliente do pool. Um teste novo derruba a conexão de um cliente emprestado: sem a correção o Vitest acusa "Unhandled Errors" e falha; com ela, passa.



Depois da correção: 16 respostas 500 (as requisições que estavam em voo no instante, 0.05%) em 32.074; o atendimento continua no segundo seguinte. Antes: processo encerrado.

Achado novo: exportação de CSV congelava a API

A exportação do histórico (50 mil linhas) montava as datas com `Intl.formatToParts` no Node — CPU síncrona que para o *event loop*. Medido com uma sonda (leitura de código a cada 50 ms) enquanto as exportações rodavam:

Cenário	Tempo da exportação	Pior espera da leitura de código
1 exportação — antes	~750 ms	~750 ms
10 simultâneas — antes	7.4 s	7.3 s
1 exportação — depois	221 ms	53 ms
10 simultâneas — depois	1.4 s	1.3 s

A formatação passou para o Postgres (`to_char` no fuso de Brasília, mesmo formato; o teste existente que confere "30/09/2026 14:05" continua passando). Ainda resta 1,3 s de congelamento com 10 exportações ao mesmo tempo — cenário improvável no uso real; o próximo passo, se preciso, é streaming com cursor.

Backup e restauração

Etapa	Resultado
<code>pg_dump -Fc</code> do banco do ensaio	0.33 s · 1.852 KB
<code>pg_restore</code> em banco novo	0.59 s · sem erros
Contagens originais	colaboradores=401 emprestimos=67161 ferramentas=1030 gatilhos=7 indices=29 ocorrencias=2 usuarios=3
Contagens restauradas	colaboradores=401 emprestimos=67161 ferramentas=1030 gatilhos=7 indices=29 ocorrencias=2 usuarios=3
Idênticas	sim OK

7. Concorrência e integridade (repetido com o código novo)

Teste	Esperado	Obtido	
50 retiradas simultâneas da mesma ferramenta	1 aceita, 49 recusadas	{'201': 1, '409': 49}	OK
usuarioRetiradaId forjado no corpo	ignorado	gravado: Colaborador Ensaio 1	OK
30 devoluções simultâneas com avaria	1 aceita, 1 ocorrência	{'200': 1, '409': 29}, 1 ocorrência (conferido no banco)	OK
30 cadastros simultâneos (gatilho novo)	30 códigos distintos	30 de 30	OK
20 operadores em retirada→devolução por 20 s	sem 5xx	16.859 ciclos, 1686 op/s	OK

```
chk          | count
-----+-----
codigos duplicados ativos |    0
ferramentas com >1 aberto |    0
em_uso sem emprestimo aberto |    0
aberto com ferramenta disponivel |    0
usuario_retirada forjado (999) |    0
(5 rows)
```

O gatilho novo manteve a garantia de códigos distintos sob disputa (mesmo advisory lock da 0005). Nota: na 1ª rodada de testes deste relatório meu script contava ocorrências por um filtro que a rota não tem; o número acima foi conferido direto no banco.

8. Segurança — rodada 2

59 de 60 casos passaram (rodada 1: 44 de 48). A única falha é o Swagger público, mantido de propósito. Os casos novos estão marcados com ★.

Categoria	Caso	Obtido	
Autenticação	Sem token	401 TOKEN_NOT_PROVIDED	OK
Autenticação	Cabeçalho malformatado	401 TOKEN_MALFORMATTED	OK
Autenticação	JWT alg=none	401 TOKEN_INVALID	OK
Autenticação	Payload adulterado (manutenção→admin)	401 TOKEN_INVALID	OK
Autenticação	JWT assinado com segredo padrão do código	401 TOKEN_INVALID	OK
Autenticação	exp alterado (token vencido)	401 TOKEN_INVALID	OK
Autorização	Manutenção edita colaborador (só admin)	403 ACCESS_DENIED	OK
Autorização	Manutenção gera link de acesso (só admin)	403 ACCESS_DENIED	OK
Autorização	Manutenção inativa ferramenta (só admin)	403 ACCESS_DENIED	OK
Autorização	Manutenção cria setor (só admin)	403 ACCESS_DENIED	OK
Autorização	Consulta lista ferramentas internas	403 ACCESS_DENIED	OK
Autorização	Consulta lê histórico de empréstimos	403 ACCESS_DENIED	OK
Autorização	Consulta lê histórico da ferramenta	403 ACCESS_DENIED	OK
Autorização	Consulta registra retirada	403 ACCESS_DENIED	OK
Autorização	Consulta lê dashboard	403 ACCESS_DENIED	OK
Autorização	Manutenção usa rota do quiosque (isolamento)	403 ACCESS_DENIED	OK
Autorização	Admin acessa rota de balcão (regra: admin $\supseteq$ manutenção)	200	OK
Autorização	Quiosque não expõe quem está com a ferramenta/valores	id,nome,categoria,status,localizacao,codigo_identificacao	OK
Injeção	SQLi na busca de ferramentas	200	OK
Injeção	SQLi na busca de empréstimos	200	OK
Injeção	SQLi no identificar colaborador	404 COLABORADOR_NOT_FOUND	OK
Injeção	ID não numérico	400 VALIDATION_ERROR	OK
Entrada	Busca com 300 caracteres	400 VALIDATION_ERROR	OK
Entrada	JSON malformatado	400 INVALID_JSON	OK
Entrada	Corpo JSON de 11 MB	413 PAYLOAD_TOO_LARGE	OK
Entrada	Prototype pollution + tipo inválido	400 VALIDATION_ERROR	OK
Upload	Texto disfarçado de PNG	400 VALIDATION_ERROR	OK
Upload	SVG (vetor de XSS)	400 VALIDATION_ERROR	OK
Upload	Path traversal em /v1/uploads	404	OK
Upload	★ Listagem do diretório de fotos	404	OK
Exposição	Erro não vaza stack em produção	{"error":{"code":"NOT_FOUND","message":"Rota não encontrada: G	OK
Exposição	Cabeçalho X-Powered-By	ausente	OK
Exposição	/v1/health público	{"status":"connected","name":null,"serverTime":"2026-10-10T00:	OK

Categoria	Caso	Obtido	
Exposição	Swagger UI em produção	200	ATENÇÃO
Cabeçalhos	strict-transport-security	presente	OK
Cabeçalhos	x-content-type-options	presente	OK
Cabeçalhos	content-security-policy	presente	OK
Cabeçalhos	x-frame-options	presente	OK
Cabeçalhos	referrer-policy	presente	OK
CORS	Origem não autorizada	ausente	OK
CORS	Origem do front autorizada	http://localhost:4174	OK
CORS	Origem de dev (5173) em produção	ausente	OK
Força bruta	Conta bloqueia após 5 senhas erradas (mesmo com a senha certa depois)	401 INVALID_CREDENTIALS, 401 INVALID_CREDENTIALS, 401 INVALID_	OK
Força bruta	Login: tempo matrícula inexistente × com conta	57 ms × 57 ms	OK
Força bruta	Limite de 10 logins/min por IP	429,429,429	OK
Força bruta	Quiosque: 6ª falha na mesma matrícula	404,404,404,404,404,429,429	OK
Força bruta	Quiosque: varredura de matrículas por IP (30/min)	7 de 30 bloqueadas	OK
Força bruta	Adivinhar link de convite (10/min)	404,404,404,404,404,404,404,404,404,404,404,429,429	OK
Sessão	★ Token da manutenção vencido há 1 dia (7 dias de validade)	401 TOKEN_EXPIRED	OK
Sessão	★ Sessão do quiosque depois dos 15 min	401 TOKEN_EXPIRED	OK
Sessão	★ Token de versão antiga (papel almoxarife)	401 TOKEN_OUTDATED	OK
Sessão	★ Token de quiosque válido nas rotas do balcão	403 ACCESS_DENIED	OK
Sessão	★ Operador inativado pelo admin no meio da sessão de 7 dias	antes 200 → depois 401 USER_INACTIVE	OK
Proxy	★ API com TRUST_PROXY_HOPS=1 acessada SEM proxy, IP forjado por tentativa	0/14 bloqueadas	OK
Proxy	★ Configuração atual (TRUST_PROXY_HOPS=0) ignora X-Forwarded-For forjado	4/14 bloqueadas	OK
CSV	★ Nome com fórmula exportado para planilha	"0602";""=HYPERLINK("http://evil.example.com","cliq	OK
Upload	★ Foto de celular 12 MP (3843 KB)	200 em 140 ms → 35 KB webp	OK
Upload	★ Imagem de 48 MP (1366 KB) acima do limite de 40 MP	400 VALIDATION_ERROR em 6 ms	OK
Upload	★ Arquivo de 17494 KB (limite 5 MB)	413 PAYLOAD_TOO_LARGE	OK
Upload	★ 10 fotos de 12 MP enviadas ao mesmo tempo	10/10 em até 463 ms	OK

Destaques

- **Revogação imediata:** operador desativado pelo admin perde o acesso na requisição seguinte, mesmo com token de 7 dias válido.
- **X-Forwarded-For:** com TRUST_PROXY_HOPS=1 e a porta da API acessível sem o proxy, 14 tentativas de login com IP forjado passaram sem nenhum bloqueio — por isso o guia agora diz explicitamente que a porta 3000 não pode ser publicada. Na configuração sem proxy (0), o IP forjado é ignorado e o limite vale.
- **Uploads reais:** foto de 12 MP (3,8 MB) vira webp de ~35 KB em cerca de 0,14 s; 10 fotos simultâneas terminam em menos de 0,5 s; imagem de 48 MP é recusada pelo limite de 40 MP do sharp (6 ms, sem estourar memória); arquivo acima de 5 MB recebe 413 (tempos exatos na tabela).
- **CSV:** nome com fórmula (=HYPERLINK(. . .)) sai neutralizado com apóstrofo na exportação.
- **Front:** CSP, X-Frame-Options DENY, nosniff, Referrer-Policy e Permissions-Policy em todas as rotas; assets com cache imutável de 1 ano e gzip (494 → 150 KB na rede).

9. Front-end: responsividade, acessibilidade e fluxos pela tela

Tela	360	768	1280	Título no cabeçalho
login	OK	OK	OK	Entrar
consulta-quiosque	OK	OK	OK	Consulta de ferramentas
dashboard	OK	OK	OK	Dashboard
ferramentas	OK	OK	OK	Ferramentas
ferramenta-detalle	OK	OK	OK	Ferramentas
retirada	OK	OK	OK	Registrar retirada
devolucao	OK	OK	OK	Registrar devolução
indisponiveis	OK	OK	OK	Indisponíveis
calendario	OK	OK	OK	Calendário
emprestimos	OK	OK	OK	Histórico
cadastro-colab-como-manutencao	OK	OK	OK	Página não encontrada
rota-inexistente	OK	OK	OK	Página não encontrada
status	OK	OK	OK	Status da API
cadastro-colaboradores	OK	OK	OK	Cadastro de colaboradores
cadastro-ferramentas	OK	OK	OK	Cadastro de ferramentas
cadastro-setores	OK	OK	OK	Cadastro de setores
cadastro-categorias	OK	OK	OK	Cadastro de categorias

Rolagem horizontal: 9 → 0. A causa era uma só: o conteúdo do layout é item flex e crescia até a largura da tabela; com min-w-0 a tabela rola dentro do próprio cartão. Operador abrindo /cadastros pela URL agora vê "Página não encontrada" também no cabeçalho e na aba.

Fluxos executados pela interface (Chrome real, teclado simulado)

Fluxo	Resultado	Detalhe
Login digitando matrícula e PIN	OK	camposNumericos: 2, aposEnterMs: 2680
Retirada pelo leitor (código + Enter, matrícula + Enter, setor, Hoje, confirmar)	OK	ferramenta: CHAVE DE IMPACTO 49, codigoLido: 0485, reconhecimentoMs: 312, operacaoMs: 916, statusApi: em_uso
Devolução com avaria (código + Enter, Avaria, descrição, confirmação)	OK	statusApi: indisponivel, motivo: avaria
Imprimir lista de cobrança no dashboard	OK	linhasImpressas: 84, esperado: 84, secoes: Atrasados (60) / Cobrar hoje (24)
Operador (manutenção) abre /cadastros pela URL	OK	titulo: Página não encontrada, aba: Página não encontrada - SOUFER Tools, menu: False, notFound: True

A retirada simula o leitor de código (digita o código e Enter): a ferramenta é reconhecida em ~0,3 s e a operação inteira — código, matrícula, setor, "Hoje", confirmar — leva menos de 1 s de sistema. A impressão gerou exatamente as 84 linhas esperadas (60 atrasados + 24 de hoje).

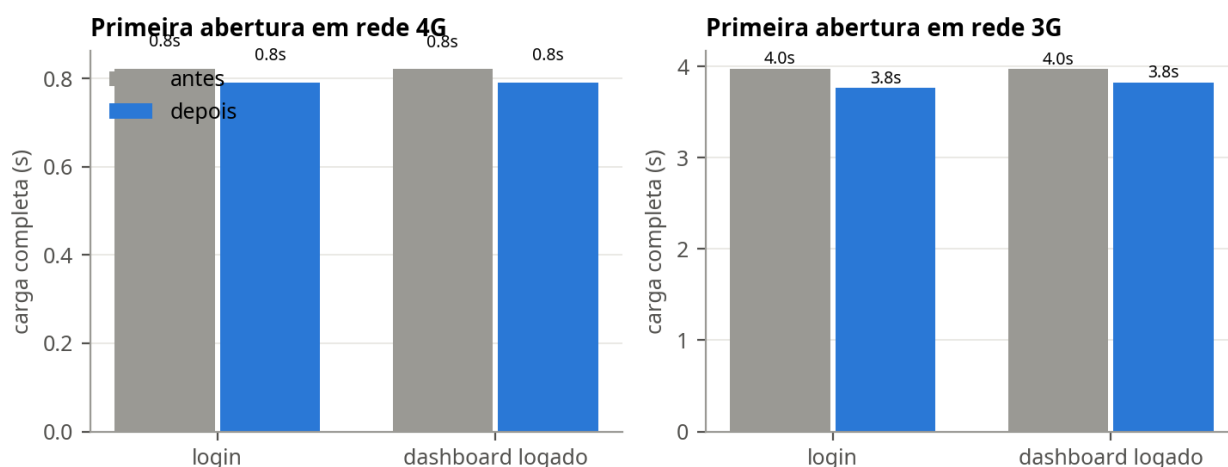
Acessibilidade (axe-core 4.10, 17 telas em 360 e 1280 px)

Impacto	Regra	Antes	Depois
critical	button-name — Buttons must have discernible text	15 telas / 15	0 telas / 0
serious	definition-list — <dl> elements must only directly contain properly-ordered <d	2 telas / 2	0 telas / 0
serious	color-contrast — Elements must meet minimum color contrast ratio thresholds	30 telas / 169	15 telas / 124
serious	list — and must only directly contain , <script> or <	5 telas / 5	0 telas / 0

Impacto	Regra	Antes	Depois
serious	listitem — elements must be contained in a or	5 telas / 5	0 telas / 0
serious	link-name — Links must have discernible text	5 telas / 5	0 telas / 0
serious	scrollable-region-focusable — Scrollable region must have keyboard access	5 telas / 5	2 telas / 2
serious	dlitem — <dt> and <dd> elements must be contained by a <dl>	2 telas / 4	0 telas / 0
moderate	landmark-one-main — Document should have one main landmark	4 telas / 4	0 telas / 0
moderate	page-has-heading-one — Page should contain a level-one heading	4 telas / 4	0 telas / 0
moderate	region — All page content should be contained by landmarks	19 telas / 127	15 telas / 109

Zerados: botão sem nome (interruptor de som), link sem nome (Status API no celular), lista do menu Cadastros, <dl> da ficha, ausência de <main>/<h1> no login e no quiosque. **Pendente (decisão de design):** o contraste que sobra é das cores de status do design system — verde #1B8A4B dá 4,39:1 no branco e 3,86:1 no fundo do badge; âmbar #C77700 dá 3,46:1; o mínimo é 4,5:1. Escurecer esses tokens é decisão da FE-01, não foi alterado aqui.

Primeira abertura em rede lenta



Build antigo × novo, sem cache. JS transferido (gzip): 282 KB → 236 KB. O ganho na primeira abertura é modesto (~5%): o gzip já comprimia bem o arquivo único. O ganho real é menos JS para o navegador interpretar (969 → 494 KB) e telas que só baixam quando usadas.

Antes × depois em 768 px (tablet) e a lista de cobrança impressa

Antes

Depois

Lista de cobrança (página 1 do PDF real da impressão)

Antes: botões de ação fora da tela

Depois: menu vira gaveta e a tabela rola dentro do cartão

Lista de cobrança (página 1 do PDF real da impressão)

Dashboard

Retirada no celular:
rodapé compacto

Quiosque no celular

Dashboard com o botão **Imprimir** no cartão Cobrar hoje

Retirada no celular:
rodapé compacto

Quiosque no celular

10. O que ainda fica (nenhum bloqueia terça)

Item	Por que ficou	Sugestão
Contraste das cores de status (verde/âmbar)	Mexe em token do design system (FE-01)	Escurecer só a variante de texto: verde ~#177A41, âmbar ~#A86400
Swagger público em produção	É entregável do PI	Restringir /docs depois da apresentação
15 avisos de lint (set-state-in-effect etc.)	Estilo; mexer em efeito na véspera é risco	Tratar depois da implantação
Admin fora do bloqueio por conta (senha de 6 dígitos)	Decisão anterior do time (evitar trancar o admin)	Manter o admin acessível só pela rede interna
Busca no histórico ~60 ms	Imperceptível hoje	Índice trigram se o histórico passar de 5 anos
10 exportações simultâneas ainda seguram a API 1,3 s	Cenário improvável	Streaming com cursor, se aparecer na prática
PR #190: diálogo "Desativar ferramenta" não fecha sozinho	Trabalho em andamento de outra branch	Fechar no onSuccess do baixar.mutate
Cabeçalhos de segurança no S3 + CloudFront	serve.json só vale no Dokploy/serve	Response headers policy no CloudFront
Onde roda na terça (servidor interno da Soufer x nuvem)	Decisão em aberto da visita técnica (5.3)	Confirmar com o TI antes de terça
Branch sem push	Aguardando autorização	Push + PR para development e revisão de 1 integrante

Checklist de terça (atualizado)

#	Item	Situação
1	Merge da branch fix/auditoria-prontidao-implantacao (migration 0011 incluída)	PR a abrir
2	Variáveis: NODE_ENV, JWT_SECRET (≥32), DB_PASSWORD forte, CORS_ORIGIN, TRUST_PROXY_HOPS=1, UPLOADS_DIR em volume	Guia atualizado
3	npm run db:migrate → npm run db:admin -- <matrícula> "<nome>" "<setor>" → npm run db:feriados	Ensaiado
4	Admin abre o link, define o PIN; importa setores, categorias, colaboradores e ferramentas (CSV)	Ensaiado: ~2 s
5	Gera link de acesso de cada operador; operador define o PIN	Ensaiado
6	Smoke test: retirada, devolução com avaria, quiosque, imprimir lista de cobrança	Ensaiado pela tela
7	Backup diário agendado + 1 restauração de teste	Testado: 0,3 s / 0,6 s
8	Porta da API não publicada; só o proxy chega nela	Documentado
9	Monitor de disponibilidade em /v1/health	Rota pronta

Apêndice — método e reprodução

- Máquina: Intel Core i5-12500H (16 threads), 16 GB RAM, Linux, Node 24, PostgreSQL 14 local. API em build de produção; front servido pelo serve com o serve.json (como no deploy).
- Rodada 1 (relatório 1): banco soufer_audit com 1.530 ferramentas e 50.300 empréstimos. Rodada 2: banco recriado do zero pelo ensaio (1.030 ferramentas, 401 colaboradores) + 50 mil empréstimos de histórico.
- Ferramentas: gerador de carga em Node puro (laço fechado, sem pausa entre requisições), Chrome headless via DevTools Protocol, axe-core 4.10.3, psql/pg_dump; nenhuma dependência nova no projeto.
- Os scripts estão em docs/testes/auditoria-2026-10-09/scripts/ junto com os dois relatórios.

```
# ensaio da terça (banco zerado)
DB_NAME=soufer_v2 npm run db:migrate
NODE_ENV=production ... node dist/scripts/criar-admin.js 0042 "Responsável" "Manutenção Geral"
node ensaio.mjs out2 # convite, importações, operador, retirada, devolução, quiosque

python3 cenarios.py out2 3998 scen2 # mesmos cenários da rodada 1
node loadtest.mjs scen2/load-50.json out2/load-50.json
bash infra.sh . # resiliência, backup/restore, exportações
node seguranca2.mjs out2 # 60 casos
node browser2.mjs out2 axe.min.js # telas, axe, fluxos E2E, rede lenta
python3 charts2.py . && python3 relatorio2.py . relatorio-2.pdf
```

Limitações

- Testes locais, não no servidor de produção; o teste de 1 núcleo aproxima mas não substitui.
- Usabilidade avaliada por fluxos automatizados e capturas, não com o operador; a primeira hora de uso acompanhado na terça continua sendo o teste definitivo.
- O leitor de código físico foi simulado (digitação + Enter), como ele funciona.